

What a WISP is

And why it is not a task you can hand to your IT provider

A **WISP** is a **Written Information Security Plan**. It is a document that states, in writing, how your firm protects taxpayer data. It names the person accountable, records the risks you identified, describes the safeguards you chose in response, and is reviewed and updated at least once a year.

It is a document, not software. No product can be purchased that *is* your WISP.

Why your firm is required to have one

Because a firm that prepares tax returns is treated as a **financial institution** under the Gramm-Leach-Bliley Act, the FTC Safeguards Rule (16 CFR Part 314) applies to you the same way it applies to a bank. IRS Publication 4557 covers the same ground for tax professionals specifically.

You have also likely already attested to this. **Form W-12, the PTIN renewal, asks you to confirm your data security responsibilities.** That confirmation is a declaration made under penalty of perjury, which means the exposure is not only that a plan is missing, but that its absence sits behind a signature you already gave.

What it has to contain

- 1 A designated Qualified Individual.** One named person accountable for the program.
- 2 A written risk assessment.** The foreseeable risks to client data, documented and current within 12 months.
- 3 The safeguards you chose.** Access controls, encryption, multi-factor authentication, logging, secure disposal.
- 4 A data inventory.** Every system and location where taxpayer information lives.
- 5 Staff security training.** Completed and documented per person, refreshed annually.
- 6 Service provider oversight.** Due diligence on every vendor touching client data, and contract language obliging them to safeguard it.
- 7 A written incident response plan.** Roles, escalation and notification contacts, decided before anything happens.
- 8 An annual written report.** Delivered by the Qualified Individual to the firm's leadership.

The part most firms get wrong

"Our IT company handles that."

This is the most common answer, and it is half true in a way that leaves firms exposed.

Your IT provider can absolutely **implement** controls: turn on multi-factor authentication, encrypt laptops, configure backups. Good ones do this well.

What your IT provider **cannot** do is be your Qualified Individual, author your firm's risk assessment, decide which risks your firm accepts, or sign the annual report to your own partners. Those obligations belong to the firm, and the name on them is a partner's, not a vendor's.

This is why forwarding this to IT usually ends with nothing happening: it is not their document to write, and most IT providers do not offer compliance documentation at all. Meanwhile the obligation, and the signature, stay with you.

What it costs to not have one

FTC enforcement. Safeguards Rule violations carry civil penalties assessed per violation, and the amounts are adjusted upward annually.

Your cyber-insurance policy. After an incident, the WISP is typically among the first documents a carrier requests. Firms have had claims contested over its absence.

Your own attestation. If you confirmed your data security responsibilities on Form W-12 without a plan in place, that is a separate exposure from the missing plan itself.

Client trust. A breach at a firm with no documented program is a very different conversation with clients than a breach at a firm that can show what it had in place.

What this actually takes

About a week, and no software installed in your office. Roughly half the requirements can be verified directly from your Microsoft 365 environment with read-only access you grant in a single click and can revoke at any time. The rest are answered by your firm through a structured questionnaire, not an essay. From those answers and your real environment we generate the plan, the risk assessment and the incident response plan for you to review and adopt.

Roberto Conde, Principal · conde@getuswisp.com · (305) 726-4103